

SOC169 - Possible IDOR Attack Detected

Đây là một số thông tin về Rule

Medium	Feb, 28, 2022, 10:48 PM	SOC169 - Possible IDOR Attack Detected	119	Web Attack
EventID :	119			
Event Time :	Feb, 28, 2022, 10:48 PM			
Rule :	SOC169 - Possible IDOR Attack Detected			
Level :	Security Analyst			
Hostname :	WebServer1005			
Destination IP Address :	172.16.17.15			
Source IP Address :	134.209.118.137			
HTTP Request Method :	POST			
Requested URL :	https://172.16.17.15/get_user_info/			
User-Agent :	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)			
Alert Trigger Reason :	consecutive requests to the same page			
Device Action :	Allowed			
Show Hint ⚙				

Device Action :Allowed

Ip nguồn : 134.209.118.137 Ip đích : 172.16.17.15 Request URL:
https://172.16.17.15/get_user_info/

Check Ip nguồn bằng AV và AbuseIPDB

1
/ 94
Community
Score

1/94 security vendor flagged this IP address as malicious

134.209.118.137 (134.209.0.0/16)
AS 14061 (DIGITALOCEAN-ASN)

US
Last Analysis
2 days ago

DETECTIONDETAILSRELATIONSCOMMUNITY 3

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis ⓘ

SOCradarMalicious

AbusixClean

0%

ISP

DigitalOcean, LLC

Usage Type

Data Center/Web Hosting/Transit

ASN

AS14061

Domain Name

digitalocean.com

Country

 United States of America

City

North Bergen, New Jersey

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

REPORT 134.209.118.137

WHOIS 134.209.118.137

IP Abuse Reports for 134.209.118.137:

This IP address has been reported a total of **1,532** times from 312 distinct sources. 134.209.118.137 was first reported on February 6th 2022, and the most recent report was **2 months ago**.

Ip nguồn được AV cảnh báo là Ip độc địa chỉ đến từ Mỹ domain IP là : digitalocean.com

tiếp theo đọc raw log từ log management : Gồm 5 alert từ Ip độc gửi đến Webserver thông qua cổng 443

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 28, 2022, 10:45 PM	Firewall	134.209.118.137	49211	172.16.17.15	443	
Feb, 28, 2022, 10:45 PM	Firewall	134.209.118.137	48523	172.16.17.15	443	
Feb, 28, 2022, 10:48 PM	Firewall	134.209.118.137	49271	172.16.17.15	443	
Feb, 28, 2022, 10:47 PM	Firewall	134.209.118.137	43261	172.16.17.15	443	
Feb, 28, 2022, 10:46 PM	Firewall	134.209.118.137	47274	172.16.17.15	443	

Thông qua raw log Ta có thể thấy Attacker gửi yêu cầu xử lý dữ liệu qua phương thức Http POST thông qua tham số ?user_id= và các yêu cầu được server chấp nhận xử lý (status

200)

```
Request URL: https://172.16.17.15/get_user_info/
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Request Method: POST
Device Action: Permitted
HTTP Response Size:: 253
HTTP Response Status: 200
POST Parameters: ?user_id=2
```

Kiểm tra EDR nào bị ảnh hưởng : Webserver1005

Endpoint Information

Host Information

Hostname: WebServer1005Domain: letsdefend.local

IP Address: 172.16.17.15Bit Level: 64

OS: Windows Server 2019Primary User: webadmin35

Client/Server: ServerLast Login: Feb, 15, 2022, 01:43 PM

Action

Containment: ☒ Host Contained

Kết Luận : Attacker ip đọc 134.209.118.137 thông qua phương thức http POST gửi các request đến https://172.16.17.15/get_user_info/?use_id=1...5 dựa vào tham số ?used_id= yêu cầu Webserver1005 xử lý , gây hậu quả rò rỉ dữ liệu người dùng nặng hơn là gián đoạn dịch vụ, làm chậm hoặc sập máy chủ.

Ngắt kết nối và hoàn thành report thôi

Practive 6

SOC170 - Passwd Found in Requested URL - Possible LFI Attack

Đây là một số thông tin về RULE

High

Mar, 01, 2022, 10:10 AM

SOC170 - Passwd Found in Requested URL - Possible LFI Attack

120

Web Attack

EventID :

Event Time :

Rule :

Level :

Hostname :

Destination IP Address :

Source IP Address :

HTTP Request Method :

Requested URL :

User-Agent :

Alert Trigger Reason :

Device Action :

Show Hint

120

Mar, 01, 2022, 10:10 AM

SOC170 - Passwd Found in Requested URL - Possible LFI Attack

Security Analyst

WebServer1006

172.16.17.13

106.55.45.162

GET

<https://172.16.17.13/?file=../../../../etc/passwd>

Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)

URL Contains passwd

Allowed

Ip nguồn : 106.55.45.162 Ip đích : 172.16.17.13 request URL : <https://172.16.17.13/?file=../../../../etc/passwd>

Check ip nguồn trên AV :

106.55.45.162 (106.52.0.0/14)
AS 45090 (Shenzhen Tencent Computer Systems Company Limited)

Community Score: 0 / 94 (-16)

No security vendor flagged this IP address as malicious

Reanalyze Similar More

CN Last Analysis Date: 1 day ago

DETECTION DETAILS RELATIONS COMMUNITY 53

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Vendor	Status	Vendor	Status
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	alohaMountain.ai	Clean

không tìm thấy kết quả Mình quyết định kiểm tra bên IPAbuse

IP Abuse Reports for 106.55.45.162:

This IP address has been reported a total of **3,459** times from 524 distinct sources. 106.55.45.162 was first reported on April 19th 2021, and the most recent report was **2 months ago**.

Old Reports: The most recent abuse report for this IP address is from **2 months ago**. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp in UTC	Comment	Categories
✓ silvelo	2024-11-25 09:29:28 (2 months ago)	SSH-Attack	Brute-Force SSH
✓ silvelo	2024-10-16 09:13:26 (4 months ago)	SSH-Attack	Brute-Force SSH
✓ silvelo	2023-11-13 10:41:37 (1 year ago)	SSH-Attack	Brute-Force SSH
✓ silvelo	2023-10-10 16:31:41 (1 year ago)	SSH-Attack	Brute-Force SSH

Kiểm tra phần báo cáo cho rằng Ip độc Nên mình sẽ check raw log ở log management:

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Mar, 01, 2022, 10:10 AM	Firewall	106.55.45.162	49028	172.16.17.13	443	

RAW LOG

Request URL: https://172.16.17.13/?file=../../../../etc/passwd

User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)

Request Method: GET

Device Action: Permitted

HTTP Response Size: 0

HTTP Response Status: 500

Ok!! nhìn vào ảnh trên ta có một số thông tin sau Ip 106.55.45.162 gửi một phương thức http GET để lấy dữ liệu server 172.16.17.13 thông qua cổng 443. bằng URL :<https://172.16.17.13/?file=../../../../etc/passwd> tuy nhiên đã bị server không phản hồi bằng status 500. điều này có nghĩa attacker không tấn công thành công.

kiểm tra EDR với ip 172.16.17.13 có tên là Webserver1006

Endpoint Information

Host Information

Hostname:	WebServer1006	Domain:	letsdefend.local
IP Address:	172.16.17.13	Bit Level:	64
OS:	Windows Server 2019	Primary User:	webadmin11
Client/Server:	Server	Last Login:	Feb, 19, 2022, 01:01 PM

Processes 15 | Network Action 2 | **Terminal History 2** | Browser History 2 | Results: 10

EVENT TIME	COMMAND LINE
19.02.2022 14:21	docker-compose -f docker-compose-deploy.yml build
19.02.2022 14:26	docker-compose -f docker-compose-deploy.yml up

< 1 >

khi kiểm tra Webserver1006 không có gì khác thường vì vậy mình chắc chắn đây là alert false positive.

Kết Luận : Ip độc 106.55.45.162 gửi một phương thức http GET thông qua request URL:<https://172.16.17.13/?file=../../../../../etc/passwd> để lấy dữ liệu từ /etc/passwd Webserver1006 nhưng không thành công.

oke thế là xong mình sẽ hoàn thành report và đóng cảnh báo